

# Security+ 1.2 · The CIA Triad

Mestre CyberSec — PDF de estudo baseado na aula do Professor Messer · 1.2 — The CIA Triad (5:17) ·

Domínio 1 · [vídeo original ↗](#) · [YouTube ↗](#)

Resumo em uma frase: **toda segurança se mede em 3 objetivos — Confidencialidade (só quem pode, vê), Integridade (dados não são alterados indevidamente), Disponibilidade (o serviço está no ar)**. Toda a arquitetura de segurança deriva destes 3. A prova pede que tu saiba identificar qual dos 3 está em risco em qualquer cenário.

## 📖 Os 3 pilares da Tríade (com seus controles)



C —

### CONFIDENCIALIDADE

#### "Só quem deve, vê"

O dado é **visto** por quem tem permissão — e por mais ninguém.

- **Encryption** — cifra o dado para que quem pegar não leia
- **Access control** — permissões (ex: marketing vê marketing, NÃO vê contabilidade)
- **MFA / autenticação** — com fatores extras, só quem credita entra
- **Steganografia** — dado escondido dentro de outro



Rompida quando: vazamento, escuta, exposição de dados



I — INTEGRIDADE

#### "O dado não é alterado indevidamente"

- **Hashing** — hash do dado no envio + no recebimento, se bater integrou
- **Digital signature** — hash criptografado (com a chave PRIVADA de quem assina) — prova integridade + autor
- **Certificates** — confiam que o dispositivo/remetente é real
- **Non-repudiation** — ninguém pode negar que enviou/recebeu

Rompida por alteração, fraude, replay, corrupção de arquivo



A — DISPONIBILIDADE

#### "O serviço está no ar quando precisas"

- **Redundância** — n+1 component, cluster, RAID
- **Failover** — troca automática pra componente saudável
- **Patching** — mantém o serviço estável e evita exploits de downtime
- **Backup e DR** — restaurar rápido após perda

Rompe com DDoS, ransomware, blackout, falha de hardware

## 🗨️ Raciocínio da pergunta (o que o Messer destaca)

### O truque de responder perguntas de CIA

A prova sempre dá um **CENÁRIO** e pergunta qual pilar foi comprometido / qual controle protege quais objetivos. O guia de decisão rápida:

- Cenário: "**seu dado foi visto/roubado**" ou "escutado" → **Confidencialidade** ferida. Controle: encriptação, ACL, MFA, classificação de dados
- Cenário: "**o dado foi alterado, o e-mail foi enviado por quem não era**" → **Integridade**. Controle: hash, assinatura digital, certificado, non-repudiation
- Cenário: "**o serviço caiu / não consigo acessar**" → **Disponibilidade**. Controle: redundância, failover, backup, DDoS mitigation, patch

### 💡 O que a prova gosta de perguntar desta aula

- **Qual dos 3 objetivos a ação compromete?** — Ex: "alguém interceptou o tráfego e viu o documento" = Confidencialidade
- **Qual controle atende ao objetivo "integridade"?** — hash, assinatura digital, non-repudiation
- **Qual ataque rompe a disponibilidade?** — DoS, DDoS, ransomware
- **O termo 'non-repudiation' já aparece na aula de Integridade** — Messer enfatiza que a assinatura digital dá integridade + autenticação + non-repudiation (o 3-em-1)

## 🔗 Como está relacionada a próxima aula — Non-repudiation

O Messer separa **Não-repúdio na 1.2 (Integridade)** e depois a destrincha em vídeo próprio **1.2 Non-repudiation (7:57)**. A tríade não tem "4º pilar" — o não-repúdio é a soma de integridade + autenticação. A prova cobra: "qual control oferece INTEgridade + autorização + NÃO REJEITA o envio?" — a resposta é sempre "**Assinatura digital**".

## ✅ Perguntas de treino (10 questões — mesmas do app)

Gabarito no fim. Tenta responder antes de olhar. Se errar 2+ aqui, re-assiste o vídeo (é curtinho, 5 minutos).

1. Um atacante intercepta e Lê uma comunicação entre dois sistemas. Que objetivo da tríade CIA foi comprometido?

- A) Integridade
- B) Confidencialidade
- C) Disponibilidade
- D) Não-repúdio

2. Um atacante INJETA código numa mensagem enviada a um banco, fazendo o banco executar uma transferência que o usuário original não ordenou. Que objetivo da tríade foi comprometido?

- A) Confidencialidade
- B) Integridade
- C) Disponibilidade
- D) Autenticação

3. Um servidor web fica inacessível por um ataque de negação de serviço distribuído (DDoS). Que objetivo da tríade CIA foi comprometido?

- A) Confidencialidade
- B) Integridade
- C) Disponibilidade
- D) Autenticidade

4. O que o HASH oferece e o que NÃO oferece?

- A) Oferece integridade; NÃO dá confidencialidade (não cifra)
- B) Oferece confidencialidade; NÃO dá integridade
- C) Oferece disponibilidade; NÃO dá integridade
- D) Oferece as 3 ao mesmo tempo

5. Qual o controle que dá, ao mesmo tempo: **integridade + autenticação do autor + non-repudiation**?

- A) Hash SHA-256 puro
- B) Criptografia AES
- C) Assinatura digital
- D) Backup do arquivo

6. O dado está sendo transmitido pela rede de um usuário pra outro servidor. Que estado de dado é este, e qual o controle típico?

- A) At rest — cifra o disco
- B) In transit — TLS/VPN
- C) In use — memória segura
- D) Rest / transit / use — todas aplicáveis

7. Uma empresa precisa garantir que a auditoria mostre, DE FORMA IRREFUTÁVEL, que o gerente enviou uma ordem de pagamento. Qual proteção é exigida?

- A) Encryption AES
- B) Non-repudiation via assinatura digital
- C) Disponibilidade de datacenter redundante
- D) Hash da mensagem sem chave

8. Uma empresa usa **hash + salt** pra guardar senhas dos usuários. Qual objetivo da tríade isso protege, e por quê?

- A) Disponibilidade — backup rápido
- B) Integridade — o hash garante que a senha não foi alterada
- C) Confidencialidade — nem quem acessa o banco consegue ler a senha (não é reversível)
- D) Autenticação — o hash prova quem o usuário é no login

9. Durante uma rotina de manutenção noturna, um script em lote com erro de lógica altera indevidamente os campos de limite de crédito de 10.000 clientes, sem dolo ou ataque externo. Qual pilar da tríade CIA foi diretamente violado?

- A) Confidencialidade
- B) Integridade
- C) Disponibilidade
- D) Não-repúdio

10. Um hospital implementa servidores de prontuário eletrônico com fontes de alimentação redundantes, gerador a diesel, replicação multi-site síncrona e balanceamento de carga automático. Essa arquitetura foi desenhada para priorizar:

- A) Confidencialidade
- B) Integridade
- C) Disponibilidade
- D) Não-repúdio

## GABARITO COMENTADO

- 1) B — Confidencialidade.** Ver o dado SEM autorização fere a "só quem pode, vê". A correção: encriptação + ACL.
- 2) B — Integridade.** O dado foi MODIFICADO — a ordem que chegou não é a que foi enviada.
- 3) C — Disponibilidade.** Serviço inacessível = down. Fim.
- 4) A — Hash dá integridade (a mesma entrada gera o mesmo hash); NÃO dá confidencialidade — não cifra o conteúdo.**
- 5) C — Assinatura digital.** Hash do documento cifrado com a chave PRIVADA: garante integridade + autentica o autor + non-repudiation (não pode negar).
- 6) B — In transit; TLS/VPN na rede** (dado viajando). At rest (parado) → cifra o disco; in use → confidential computing / enclaves.
- 7) B — Non-repudiation via assinatura digital:** prova irrefutável de que foi o gerente que enviou (com a chave PRIVADA dele).
- 8) C — Confidencialidade.** Guardar hash + salt da senha significa que NEM QUEM VÊ O BANCO consegue ler a senha (não reversível) — protege o segredo, não a integridade do arquivo de senhas.
- 9) B — Integridade.** A modificação incorreta dos dados contábeis corrompeu a exatidão e a integridade da base, independentemente de ter havido dolo.
- 10) C — Disponibilidade.** No-breaks, geradores, replicação e redundância existem para assegurar que os médicos acessem os prontuários 24/7 sem interrupções.

## Links desta aula

[Página oficial da aula ↗](#) · [Course Notes \(PDF pago do Messer\) ↗](#) · [Objectives oficiais ↗](#)